FDE SCENARIO DRILLS #04

FDE SCENARIO DRILLS · ISSUE 04 OF 08

Security found personal data in our logs.

Scenario: full prompts with customer emails were logged at INFO.

04

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Today

01 **Stop the leak**

Redaction in the pipeline, then a hotfix to stop logging prompts.

02 **Scope it**

Which services, since when, which log stores, who has access.

03 **Purge**

With the customer, under their retention and legal rules.

04 **Report**

Written timeline, cause and fixes, same day.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

What we log now

BEFORE

- Full prompt and response
- Email addresses
- Raw tool arguments
- Debug level in production

AFTER

- Request id and trace id
- Token counts and latency
- Hashed or masked fields
- Prompt capture opt-in, short retention

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Defence in depth

1. Log ids, not payloads
2. Redact in the collector
3. Restrict log access
4. Short retention
5. Test for leaks in CI

AR
Akhilesh Ranjan Singh
github.com/iarsingh

THE LESSON

Logs are a data store. Treat them like one.

Same classification, access control and retention as the database.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

What interviewers listen for

- [x] Urgency without panic
- [x] Customer kept informed
- [x] Fix the source, not only the symptom
- [x] Retention and access considered
- [x] A test so it cannot return

AR
Akhilesh Ranjan Singh
github.com/iarsingh

KEY TAKEAWAY

If you would not store it in the database, do not log it.

→ Log identifiers, not content

→ Redact centrally, before export

→ Add a test that fails on leaks

YOUR TURN

Does your team test logs for personal data?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #05 The CDC slot that filled the disk

Save · Repost

AR
Akhilesh Ranjan Singh
github.com/iarsingh